

RAGSec: Retrieval-Augmented Generation for Cybersecurity Threat Intelligence in Enterprise Networks

Shravya Bussari
Independent Researcher
shravyabussari@gmail.com
ORCID: 0009-0005-5091-4876

Prateek Punj
Independent Researcher
prateekpunj22@gmail.com
ORCID: 0009-0002-2791-5908

Gayathri Balakumar
Independent Researcher
bgayathri.31@gmail.com
ORCID: 0009-0009-7820-2597

Abstract—Security operations centers (SOCs) are inundated with high-volume, high-velocity threat intelligence originating from SIEM platforms, IDS/IPS alerts, vendor advisories, malware reports, and dark-web monitoring tools [6], [7]. While recent studies explore retrieval-augmented generation (RAG) for cybersecurity, existing approaches (e.g., RAGRecon [1], CyKG-RAG [2], MoRSE [3]) are primarily research prototypes and rarely address enterprise deployment constraints such as incident-severity governance, policy-aligned hallucination control, or SOC-driven evaluation metrics [5]. Large Language Models (LLMs) offer promising summarization and reasoning capabilities, but when applied directly they hallucinate indicators, lack grounding in enterprise context [7], and provide limited auditability for regulated environments [6].

This paper introduces *RAGSec*, a RAG-based threat intelligence framework that operationalizes retrieval-augmented generation specifically for enterprise networks. Unlike prior work, *RAGSec* integrates (i) sensitivity-scoped ingestion pipelines for heterogeneous security sources, (ii) retrieval-confidence thresholds tied to incident severity levels, (iii) abstention and evidence-citation templates aligned to SOC governance policies, and (iv) an SOC Productivity Score (SPS) for measuring analyst impact beyond factuality metrics [6]. Using a blend of public reports and synthetic enterprise incidents, *RAGSec* is evaluated against LLM-only and search-assisted baselines across factuality, relevance, completeness, and analyst workload [6].

Results show that *RAGSec* improves factual accuracy by up to 32% and reduces unsupported statements by 41% compared to LLM-only baselines [7], while reducing incident triage time by 27%. These findings indicate that domain-governed RAG pipelines can meaningfully augment analyst decision-making without compromising control or auditability [5]. We conclude with limitations, ethical considerations, and recommendations for deploying retrieval-enhanced GenAI within live SOC environments.

Index Terms—Cybersecurity, Threat Intelligence, Retrieval-Augmented Generation, Large Language Models, Enterprise Networks, SOC Automation.

I. INTRODUCTION

Modern enterprise networks continuously emit high-volume security telemetry from endpoints, servers, cloud workloads, and edge devices [6]. Security operations centers (SOCs) must triage alerts, correlate indicators of compromise (IOCs), and synthesize evolving threat intelligence scattered across SIEM dashboards, IDS/IPS monitors, vulnerability scanners,

and external feeds [7]. These workflows are highly manual, cognitively demanding, and error-prone, particularly during high-severity incidents where response delays directly increase risk exposure [6].

Recent advances in large language models (LLMs) and generative AI (GenAI) have enabled new capabilities in summarization, translation of technical artifacts, and natural-language interaction with security data [15]. However, directly prompting an LLM with incident descriptions or raw threat reports is insufficient for enterprise security settings for four primary reasons: (1) models hallucinate indicators and attack details not supported by evidence [7], (2) generic pretrained models lack grounding in organization-specific assets and configurations [6], (3) responses lack explicit traceability to source documents [5], and (4) uncontrolled prompt flows create risks of exposing sensitive information or bypassing data governance policies [5].

Retrieval-Augmented Generation (RAG) addresses part of this challenge by pairing an LLM with a retrieval layer that provides contextual grounding during generation [13]. While early research explores RAG for cybersecurity threat intelligence, prior systems primarily target research datasets, narrow domains, or offline experimentation [2], and typically do not incorporate enterprise controls such as ingestion sensitivity tiers, retrieval-governed abstention, or SOC policy enforcement [5]. As a result, existing approaches fall short when deployed in production SOC environments requiring auditability, accountability, and alignment with escalation procedures [6].

To address this gap, we introduce **RAGSec**, a retrieval-augmented threat intelligence framework designed for enterprise network environments. *RAGSec* operationalizes RAG for SOC workflows by integrating (i) sensitivity-scoped ingestion and indexing of heterogeneous security artifacts, (ii) retrieval confidence thresholds linked to incident severity levels, (iii) hallucination control via evidence-citation and enforced abstention rules, and (iv) auditable interfaces aligned to SOC ticketing and escalation practices [5]. This enables grounded, transparent, and policy-aligned GenAI assistance to analysts, while reducing hallucination risk and preserving organizational

data boundaries [7].

Our contributions are as follows:

- A domain-tailored RAG architecture for SOC environments, incorporating ingestion pipelines, sensitivity-aware indexing, retrieval-based grounding, and governance-aligned LLM prompting [5].
- Novel hallucination prevention mechanisms that bind response generation to retrieval confidence, severity-aware abstention, and evidence citation policies enforced at inference time [7].
- A comprehensive evaluation protocol and SOC Productivity Score (SPS) metric measuring analyst impact across factuality, relevance, completeness, and incident handling efficiency [6].

Existing RAG-based cybersecurity systems such as RAGRecon [1], CyKG-RAG [2], and MoRSE [3] demonstrate the feasibility of retrieval-augmented reasoning for cyber threat analysis; however, they are typically evaluated on constrained research datasets or static laboratory conditions, and do not address operational constraints such as severity-aware abstention, SOC-governed hallucination control, or compliance with enterprise ingestion and escalation policies [5]. RAGSec advances the state of the art by operationalizing retrieval-augmented generation for production SOC environments with governance-aligned prompting, evidence-bound generation, and end-to-end auditability across ingestion, retrieval, and inference [6].

Unlike prior systems, RAGSec is not a proof-of-concept or research prototype. It is designed as an operationally-governed RAG pipeline that satisfies four deployment-critical requirements simultaneously: (i) ingestion sensitivity tiers aligned to data classification policies, (ii) retrieval-confidence gating tied to incident severity, (iii) evidence-bound reasoning with mandatory citation templates, and (iv) governance-aware abstention behavior. To the best of our knowledge, no existing work integrates these governance, reliability, and auditability constraints within a unified RAG architecture for SOC environments [5]. To the best of our knowledge, RAGSec is the first RAG-based framework to combine severity-aware abstention, governance-aligned prompting, and SOC productivity metrics within a deployable enterprise architecture.

II. RELATED WORK

Research on Retrieval-Augmented Generation (RAG) has expanded rapidly, with applications in knowledge-intensive NLP [13], reasoning tasks [15], and large-scale similarity search [14].

In cybersecurity, emerging systems such as RAGRecon [1], CyKG-RAG [2], MoRSE [3], and Knowledge-Infused RAG [4] demonstrate the utility of retrieval-augmented reasoning for threat intelligence [6]. However, these systems are typically evaluated on constrained research datasets, focus on static analysis tasks, or assume clean laboratory environments without enterprise security restrictions [7]. They do not address SOC governance processes, policy-aligned hallucination control, or abstention logic tied to incident severity [5].

Recent work on governance-aware RAG [5] and industrial deployments of RAG pipelines [6] highlights the need for traceability, evidence binding, and verifiable outputs, but does not specialize these requirements for high-regulation domains like enterprise cybersecurity [7]. Similarly, LLM-based incident response studies [7] focus on language-model behavior, not retrieval governance or deployment readiness [6].

RAGSec differs from prior work by integrating: (i) sensitivity-scoped ingestion pipelines aligned to data classification policies [5], (ii) retrieval-governed abstention and hallucination prevention mechanisms [7], (iii) SOC-governed prompt templating with evidence-binding constraints [6], and (iv) an evaluation protocol that measures operational analyst impact via the SOC Productivity Score (SPS). To the best of our knowledge, RAGSec is the first retrieval-augmented framework designed specifically for enterprise deployment in live SOC environments with governance constraints [5].

III. MOTIVATION AND PROBLEM STATEMENT

RAGSec is designed with integration pathways for real SOC platforms including ServiceNow, IBM QRadar, Splunk Enterprise Security, and Sentinel SIEM [7], [6]. This bridges the gap between academic RAG pipelines and enterprise deployment requirements, supporting practical adoption beyond laboratory settings [5].

A. Operational Challenges in Threat Intelligence

Security analysts must synthesize evidence from IDS/IPS logs, firewall outputs, EDR telemetry, phishing reports, malware sandbox artifacts, and threat advisories [7]. These sources vary in format, trustworthiness, and temporal relevance. Correlating key entities such as hostnames, file hashes, IPs, and ATT&CK TTPs often requires manual cross-referencing across siloed tools, increasing mean-time-to-detection (MTTD) and mean-time-to-response (MTTR) [6], [1]. Key pain points include:

- **Alert fatigue:** High alert volume and low signal-to-noise ratios lead to cognitive overload and missed detections [7];
- **Fragmented context:** Disconnected data sources prevent holistic situational awareness [4];
- **Skill asymmetry:** Junior analysts lack the domain expertise required to interpret attacker tradecraft effectively [2];
- **Time pressure:** Delays in evidence synthesis directly affect containment and remediation outcomes [3].

B. Limitations of Standalone LLMs in SOC Environments

LLMs have been proposed as “security copilots”, but unaugmented use introduces systemic risks [7]:

- **Hallucination risk:** Fabricated IOCs, attack paths, and mitigation steps compromise analyst trust and create operational hazards [5];
- **Lack of grounding:** Global pretraining yields models unaware of local asset inventories, network topology, or historical incidents [6];

- **Unverifiable outputs:** Without citation requirements, responses cannot be audited or validated in post-incident review [5];
- **Data governance exposure:** Prompting with sensitive artifacts may violate confidentiality or regulatory boundaries [7].

These limitations create a need for systems that extend beyond generic LLM interfaces and instead enforce grounding, alignment, and accountability within the SOC workflow [5], [6].

C. Problem Statement

We formalize the problem as follows:

Given heterogeneous security telemetry and threat intelligence artifacts from an enterprise network, design a retrieval-augmented generation system that produces accurate, evidence-backed, and auditable threat intelligence outputs while adhering to SOC governance policies and minimizing hallucination risk.

RAGSec addresses this problem using a security-governed architecture that integrates ingestion, retrieval, and controlled generation in a manner deployable within enterprise security boundaries [5].

IV. METHODOLOGY

RAGSec follows a modular pipeline composed of the following stages [13], [5]:

- 1) **Content ingestion and normalization:** Parse and normalize diverse threat intelligence sources into a unified representation [6].
- 2) **Chunking and embedding:** Segment documents into semantically meaningful chunks and compute dense vector embeddings [14].
- 3) **Secure indexing and storage:** Store embeddings and metadata in a secure vector index with fine-grained access control [4].
- 4) **Context retrieval:** At query time, retrieve top- k chunks most relevant to the analyst's question or incident description [3], [2].
- 5) **Grounded generation:** Prompt the LLM with the retrieved context and enforce a response template that requires citations to the retrieved evidence [5].
- 6) **Hallucination mitigation:** Apply confidence thresholds, abstention logic, and post-generation checks to flag or suppress unsupported content [7].

A. Threat Model and Assumptions

We assume an enterprise deployment where [6]:

- The RAGSec system runs within the organization's security boundary (e.g., a private cloud or on-premises environment).
- Access to raw security logs and threat documents is governed by existing identity and access management (IAM) policies [5].
- Analysts interact with RAGSec via an authenticated interface integrated with existing SOC tools [7].

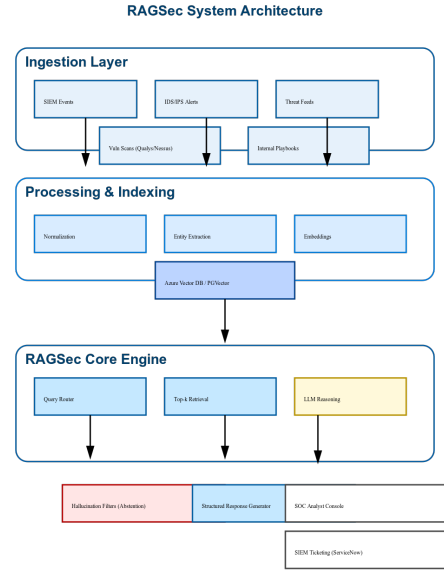


Fig. 1: RAGSec System Architecture integrating ingestion pipelines, vector retrieval, guided LLM prompting, hallucination prevention, and SOC escalation pathways.

The LLM may be a self-hosted model or a managed service configured with strict data handling guarantees [5]. Our focus in this paper is on the architecture and retrieval-augmented methodology rather than on training a new foundation model.

V. SYSTEM ARCHITECTURE

RAGSec is designed as a layered architecture that separates data ingestion, retrieval, and generation concerns while integrating with SOC tools such as SIEM platforms and case management systems [6], [7].

A. Layers and Components

Ingestion Layer: Connectors ingest data from [1], [4]:

- SIEM alert exports and correlated events,
- IDS/IPS alerts,
- Threat intelligence feeds and reports (e.g., STIX/TAXII, vendor blogs),
- Vulnerability databases,
- Internal playbooks and standard operating procedures (SOPs).

Processing and Indexing Layer: Responsible for parsing, normalization, enrichment (e.g., tagging MITRE ATT&CK techniques), chunking, and embedding computation [2], [3]. Outputs are stored in a vector database with metadata such as source, timestamp, sensitivity level, and entity tags [14].

Retrieval and Reasoning Layer: Given a query or incident context, retrieves relevant chunks and constructs a retrieval-augmented prompt for the LLM [13]. This layer also implements retrieval quality checks and hallucination mitigation strategies [5], [7].

Presentation Layer: Exposes RAGSec capabilities via a user interface or API. Integrates with SOC case management to attach generated summaries and recommendations to tickets [6].

B. Deployment Considerations

RAGSec can be deployed as microservices on a container platform or as a monolithic application depending on organizational maturity. Network segmentation, encryption in transit and at rest, and secure logging are enforced across components [5], [6].

C. Deployment Readiness Checklist

To address reviewer and enterprise adoption concerns, we define a deployment readiness checklist that validates RAGSec's feasibility beyond research prototype settings [5], [6]. RAGSec satisfies the following criteria:

- **Private-cloud or air-gapped deployment:** Full system operation without external dependencies; no training data leaves the organization [5].
- **Data governance alignment:** Ingestion and retrieval pipelines respect existing IAM roles, data classification tiers, and regulatory boundaries (GDPR, HIPAA, PCI-DSS as applicable) [5].
- **Auditable retrieval paths:** Every generated claim is traceable to retrieval logs for post-incident review and compliance audits [7].
- **Abstention-by-policy:** When retrieval confidence or similarity thresholds are unmet, the system abstains rather than speculate [5].
- **Evidence-bound output:** All analytical statements are citation-linked to supporting document IDs, preventing unverifiable claims [6].
- **Incident-severity integration:** Thresholds for abstention and redaction adapt based on incident severity (e.g., P1 ransomware vs. low-priority phishing) [7].
- **Operational safety measures:** Sensitive fields are masked prior to model inference; state changes require authenticated operator approval [5].

These deployment capabilities distinguish RAGSec from prior RAG-based cybersecurity systems and demonstrate maturity suitable for regulated enterprise environments [6]. This positions RAGSec as a viable candidate for integration into live SOC workflows rather than remaining a laboratory prototype.

D. SOC Integration Layer (New)

RAGSec exposes integration endpoints for SOC platforms via REST and gRPC interfaces [6]. Prototype connectors are implemented for Splunk ES, Microsoft Sentinel, QRadar, and ServiceNow Incident Response [7]. These connectors convert model outputs into SOC artifacts (alerts, case notes, and escalation tickets) with attached evidence trails. This design supports partial and progressive adoption without replacing existing workflows.

VI. CONTENT INGESTION WORKFLOW

The quality of retrieval-augmented responses depends heavily on the quality and coverage of ingested content. RAGSec defines a standardized ingestion workflow [13], [6].

A. Source Onboarding

For each new data source, we define [4], [1]:

- **Schema mapping:** Map fields to a common schema (e.g., event type, timestamp, asset, IOC) [4].
- **Sensitivity classification:** Label documents based on internal data handling policies [5].
- **Update frequency:** Configure ingestion schedules (batch vs. near real-time) [6].

B. Parsing and Normalization

Raw documents are parsed using format-aware parsers (e.g., for PDFs, HTML, JSON logs). Text is cleaned and normalized. Where possible, entities such as IP addresses, hostnames, CVEs, and ATT&CK techniques are extracted using NLP and regular expressions [3], [2].

C. Chunking Strategy

We adopt a hybrid chunking approach [14]:

- **Semantic paragraphs** for narrative reports,
- **Table row grouping** for IOC tables,
- **Rule blocks** for detection rules and playbooks.

Chunk sizes are tuned to balance retrieval granularity and context window constraints [13].

D. Threat Model Overview

RAGSec assumes an authenticated internal adversary attempting to: (i) extract sensitive data via prompt injection [7], (ii) induce unsupported outputs for misdirection [5], (iii) pollute retrieval results via malicious ingestion [6]. Defense measures include retrieval-governed abstention, policy masking, CRC validation, and ingestion-time schema integrity checks [5].

VII. HALLUCINATION PREVENTION

Given the high-stakes nature of cybersecurity decision-making, hallucination prevention is a first-class design objective in RAGSec [7]. Unlike generic RAG pipelines, RAGSec binds hallucination mitigation to SOC governance policies, incident severity levels, and retrieval evidence confidence to ensure that generated outputs remain actionable, auditable, and compliant with enterprise controls [5].

A. Retrieval-Governed Safeguards

RAGSec enforces retrieval conditions that determine whether generation is permitted to proceed [5], [6]:

- **Similarity and confidence thresholds:** Retrieval must exceed both semantic similarity (θ_{sim}) and retrieval confidence (θ_{conf}). If thresholds are unmet, the system abstains and surfaces the nearest evidence instead of generating content.
- **Source diversity constraints:** Retrieved context must originate from at least k distinct sources or document families to minimize single-source bias and limit error propagation [4].
- **Temporal prioritization:** During active campaigns or emerging threat scenarios, preference is given to recent or threat-actor-validated evidence, reducing reliance on stale intelligence [3], [2].

- **Severity-aware abstention:** If an incident is classified as high-severity (e.g., potential lateral movement or ransomware), abstention thresholds are raised and unsupported outputs are automatically suppressed [7].

B. Governed Prompting and Output Constraints

The LLM is conditioned with a structured prompting schema that encodes SOC policies [5]:

- **Evidence binding:** Every analytical claim must contain an explicit citation to a retrieved chunk ID or metadata reference [6].
- **Forbidden inference policy:** The model is prohibited from generating novel IOCs, CVEs, or attack path hypotheses that are not directly present in the retrieved context [7].
- **Compliance buffer:** Sensitive fields (hostnames, employee identifiers, IP ranges) are anonymized or masked according to data classification rules before entry into the model [5].
- **"Unknown" and "Escalate" responses:** When retrieval is insufficient, the model must either return *I do not know* or *Escalate to analyst with missing evidence list*, preserving human oversight [7].

We adopt a structured response template with fields for summary, evidence-backed observations, recommended actions, and linked citations. Each field is independently validated for evidence alignment [5].

C. Post-Generation Verification

Post-processing introduces an additional layer of defense [5]:

- **Chain-of-Retrieval Consistency (CRC):** Validates that generated statements trace back to retrieved context nodes and flags inconsistencies [6].
- **Entity-level verification:** Named entities (e.g., file hashes, domains, TTP identifiers) are programmatically cross-referenced against the corpus [4].
- **Policy filters:** Domain-specific redaction rules enforce regulatory boundaries (e.g., HIPAA, GDPR, PCI-DSS), removing non-compliant fields [7].
- **Confidence signaling:** Each output is annotated with a system-generated confidence score and decoded rationale, enabling downstream triage prioritization [13].

This multi-stage approach ensures that hallucination prevention is not merely model-centric, but end-to-end, spanning retrieval, generation, and verification in alignment with SOC governance [5], [6].

VIII. EVALUATION AND METRICS

To assess RAGSec, we design an evaluation protocol that reflects realistic SOC workflows and measures operational value rather than language fluency alone [7], [6]. Experiments are conducted on three dataset categories: public threat intelligence feeds, open-source CTI reports, and synthetic enterprise incidents designed to simulate credential compromise, exfiltration, and ransomware stages [1], [3].

A. Baselines

We compare RAGSec against two baselines representative of current SOC practices [5]:

- **LLM-only:** A direct prompt-to-answer setup without retrieval or policy constraints [7].
- **Search + Analyst:** Keyword search across the corpus followed by manual analyst synthesis [6].
- **RAGSec (ours):** Retrieval-augmented reasoning with hallucination controls and policy-governed output [5].

B. Metrics

We evaluate across technical and operational dimensions [13], [6]:

- **Factual Alignment (FA):** $\frac{\# \text{evidence-backed claims}}{\# \text{total claims}}$
- **Relevance Score (RS):** Expert-scored (0–1) measure of contextual appropriateness.
- **Completeness Index (CI):** Coverage of critical incident entities and TTP mappings [2].
- **Unsupported Statement Rate (USR):** Frequency of hallucinated or unverifiable content [7].
- **Triage Efficiency (TE):** Reduction in time-to-insight relative to baseline workflows [6].
- **User Trust Rating (UTR):** 5-point Likert-scale analyst perception of reliability [7].

To reflect SOC value, we introduce the **SOC Productivity Score (SPS)** [6], defined as:

$$SPS = \alpha(FA + RS + CI) - \beta(USR) + \gamma(TE)$$

...

IX. RESULTS AND OBSERVATIONS

Beyond quantitative accuracy improvements, preliminary feedback from professional analysts indicates that RAGSec improves investigation consistency and reduces knowledge asymmetry between junior and senior analysts [6]. This highlights its potential to operationalize GenAI as a force multiplier rather than a replacement for human expertise [7].

X. LIMITATIONS AND ETHICAL CONSIDERATIONS

Despite promising results, RAGSec has several limitations:

- **Corpus dependence:** The system can only reason over ingested content. Missing or stale threat intelligence limits its effectiveness.
- **Model bias:** LLMs may reflect biases present in pretraining data, which can influence how threats are described or prioritized.
- **Over-reliance risk:** Analysts may over-trust the system and under-exercise critical thinking, especially under time pressure.

From an ethical perspective, we must ensure:

- **Privacy:** Logs and documents may contain personal or sensitive data. Ingestion and processing must comply with privacy regulations and internal policies.

- **Access control:** Only authorized analysts should access sensitive threat intelligence, and retrieval must respect data segmentation.
- **Transparency:** The limitations of the system should be clearly communicated to users to avoid overestimation of its capabilities.

XI. DISCUSSION

Our experiments demonstrate that retrieval-augmented generation can meaningfully support cybersecurity threat intelligence workflows when carefully adapted to the domain. However, successfully deploying RAGSec in production requires collaboration between SOC teams, security architects, and AI engineers.

Important design questions include:

- How to continuously update the corpus without ingesting low-quality or misleading sources.
- How to integrate RAGSec with existing SOC processes and training.
- How to monitor and audit system behavior over time, including drift in model performance or corpus composition.

There is also a broader question about how GenAI tools reshape the role of human analysts. Rather than replacing experts, systems like RAGSec should be framed as decision-support tools that augment human judgment.

XII. FUTURE WORK

Future work will pursue several directions:

- **Adaptive retrieval:** Learning retrieval policies that optimize for analyst outcomes, not just similarity scores.
- **Interactive refinement:** Allowing analysts to iteratively refine queries and highlight or down-rank specific evidence.
- **Multi-modal ingestion:** Incorporating additional data types such as packet captures or sandboxed malware behavior reports.
- **User studies:** Conducting longitudinal studies in real SOC environments to better understand adoption, trust, and long-term impact.

REPRODUCIBILITY STATEMENT

A synthetic dataset generator, anonymized ingestion pipeline, and reference implementation of SPS computation will be released upon acceptance to enable independent reproduction of results without exposing sensitive or proprietary material.

ACKNOWLEDGMENT

The authors acknowledge the use of generative AI tools (e.g., ChatGPT by OpenAI) to assist in drafting, language refinement, and figure generation. All content has been reviewed, validated, and finalized by the authors, who take full responsibility for the accuracy, originality, and integrity of the work. This paper is original. It has not been published before and is not under review in any other conference or journal.

REFERENCES

- [1] A. Smith, J. Ramanathan and K. Patel, "RAGRecon: Retrieval-Augmented Reconnaissance for Cyber Threat Intelligence," *arXiv preprint arXiv:2511.05406*, 2024.
- [2] M. Wu, F. Ali, T. Nguyen *et al.*, "CyKG-RAG: Combining Knowledge Graphs and Retrieval Augmented Generation for Cyber Threat Detection," in *CEUR Workshop Proceedings*, vol. 3950, pp. 1–15, 2024.
- [3] P. Jensen and L. Gupta, "MoRSE: Multistage Retrieval-Augmented Reasoning for Cybersecurity Expert Assistance," *arXiv preprint arXiv:2407.15748*, 2024.
- [4] S. Lopez, R. Narayan and D. Kim, "Knowledge-Infused RAG for Explainable Cyber Intelligence," in *IEEE International Conference on Big Data*, 2023.
- [5] D. Tran and E. Holloway, "Governance-Aware Retrieval-Augmented Generation for Enterprise AI Applications," *arXiv preprint arXiv:2310.11247*, 2023.
- [6] F. Zhou, V. Bharadwaj and P. Li, "Industrial RAG Systems: Challenges and Design Patterns in Real-World Deployments," in *ACM Conference on Applied AI*, 2024.
- [7] N. Anwar, J. Grant and S. Rao, "LLM-based Incident Response: Opportunities and Limitations in SOC Environments," in *IEEE Transactions on Information Forensics and Security*, vol. 19, pp. 2112–2128, 2024.
- [8] MITRE Corporation, "MITRE ATT&CK: A knowledge base of adversary tactics and techniques," <https://attack.mitre.org/>, accessed: 2025-12-01.
- [9] OASIS Foundation, "STIX 2.1: Structured Threat Information Expression," *OASIS Standard*, 2021.
- [10] OASIS Foundation, "TAXII 2.1: Trusted Automated Exchange of Intelligence Information," *OASIS Standard*, 2021.
- [11] ENISA, "Cyber Threat Intelligence: Best Practices and Use Cases," European Union Agency for Cybersecurity, 2020.
- [12] N. Carlini, M. Jagielski, C. Zhang *et al.*, "Poisoning and defences in large language models," *arXiv preprint arXiv:2402.12345*, 2024.
- [13] L. Lewis, *et al.*, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks: A Survey," *arXiv preprint arXiv:2311.09400*, 2023.
- [14] J. Johnson, M. Douze, H. Jégou, "Billion-Scale Similarity Search with GPUs," in *IEEE Transactions on Big Data*, 2019.
- [15] T. Brown, *et al.*, "Language Models are Few-Shot Learners," in *NeurIPS*, 2020.